

B U P T

密码工程

第15讲、5G中的安全协议、区块链

授课教师：王晨宇

时间：2026年6月14日



期末考查

B U P T

成绩组成:

- 课后作业：调研资料学习 50%
- 期末考查：提交密码工程相关领域的研究报告 50%，
2026年6月24日之前，提交到教学云平台

6.3

5G中的安全协议

► 5G中的安全协议



- ✓ 6.3.1 移动通信安全的历史进程
- ✓ 6.3.2 移动通信面临的安全威胁
- ✓ 6.3.3 5G中的认证机制简介
- ✓ 6.3.4 5G-AKA
- ✓ 6.3.5 EAP-AKA



移动通信安全的第一个问题：你是谁？

□ 手机通信的第一个关键问题

□ 如何确认“请求连接的是不是本人”。

□ 在固定网络中容易验证身份，但移动通信用户是“到处跑的”，不好确认。

□ 如果不能确认身份，黑客就能假冒别人接入网络，造成盗打、诈骗等问题。

□ 接下来让我们看看，不同“通信时代”是怎么一步步解决这个问题的。



5G中的安全协议

6.3.1 移动通信安全的历史进程(2)

B U P T

1G-没有密码的通信时代

□ 1G时代的手机像“对讲机”：

□ 不加密、不验证。

□ 用户的身份信息（像身份证号）是明文广播出去的，别人一听就知道。

□ 黑客很容易克隆手机，冒充别人打电话。

□ 就像你的银行卡号和密码在广播，谁都能用，很不安全。



5G中的安全协议

6.3.1 移动通信安全的历史进程(3)

B U P T

2G-开始用对称密钥，但问题依旧不少

- 2G时代开始引入加密，用对称密钥做身份认证。
- 但它只能验证“你是谁”，没法确认“对面是不是假基站”。
- 加密方式也比较弱，传一次可以被别人复制很多次使用。



2G-开始用对称密钥，但问题依旧不少

□ 此时存在多个问题，比如：

- 单向身份认证，移动设备无法鉴别基站的身份。
- 用户身份容易在空中接口暴露。
- 无数据完整性检验机制。
- 核心网缺乏加密和认证机制。
- 无第三方仲裁功能，容易出现计费纠纷。
- 用户漫游时，服务网络采用的认证参数与归属网络没有有效联系。
- 用户无法选择安全性，且用户密钥固定不变，缺乏安全升级功能。



5G中的安全协议

6.3.1 移动通信安全的历史进程(5)

B U P T

3G-第一次实现双向验证和完整性保护

- 3G系统能实现“你验证网络、网络也验证你”，防止假基站。
- 还加入了“完整性校验”，防止有人在中间偷偷改数据。
- 在后台，手机和网络用数学算法动态生成密钥，不再使用固定密钥。
- 但它仍有问题，比如：
 - 多张SIM卡共用同一个计数器，一出错就全崩。
- 总体来看，3G在安全性上是一次大升级。



5G中的安全协议

6.3.1 移动通信安全的历史进程(6)

B U P T

4G-安全不只在无线，还扩展到了全网

- 4G不是只保护手机到基站，而是把安全扩展到整个网络。
- 引入了更强的加密算法，加入了更多认证参数。
- 不过，4G也带来新挑战，比如：
 - 多网共享，隐私保护更复杂；
 - 和互联网连接紧密，攻击面也随之扩大。



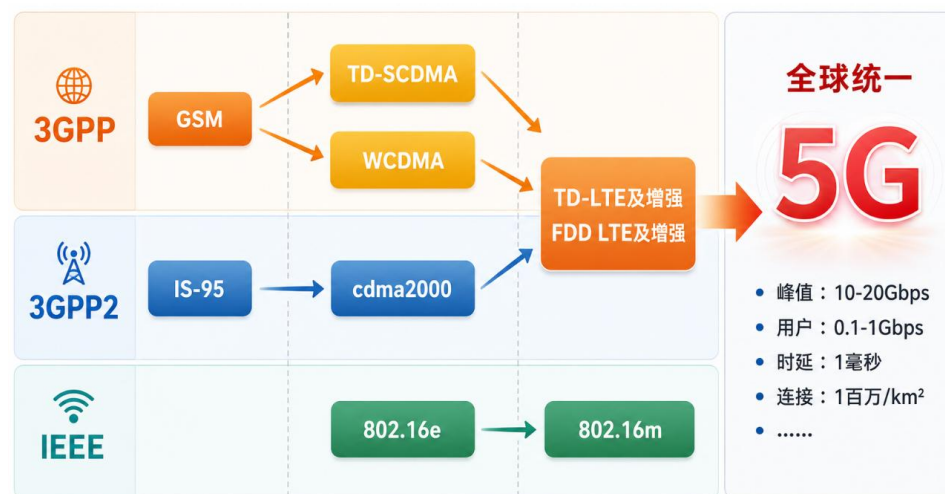
5G中的安全协议

6.3.1 移动通信安全的历史进程(7)

B U P T

5G-不仅更快，也面临更复杂的安全挑战

- 5G不仅提升了网络速率和接入密度，还引入了虚拟化、切片、边缘计算等新架构，安全管理更复杂。
- 安全机制上，5G进一步强化了身份认证、密钥协商和信令保护机制，并支持设备、网络和服务多层协同安全。





5G-不仅更快，也面临更复杂的安全挑战

□与此同时，5G也带来了新的安全威胁，例如：

- 网络切片共享资源，若隔离失效，可能出现跨租户攻击；
- 边缘计算下沉，攻击者可从边缘节点入手，渗透核心网络；
- 海量IoT终端接入，设备安全性差，成为攻击跳板。



无线/有线链路上的安全威胁

- (1) **窃听**: 由于链路开放, 攻击者可能监听用户的信令、数据、密钥交换等过程, 获取隐私信息。特别是在无线环境中, 未加密信息容易被截获、分析。
- (2) **伪装**: 攻击者可能伪装成基站或终端, 诱导用户连接, 从而绕过认证机制, 非法访问网络。
- (3) **破坏完整性**: 恶意方可能篡改、插入、重放或删除用户数据与信令, 影响网络服务的正常运行。
- 链路层失效还可能导致终端与网络信息不同步, 提升误码率, 影响通信稳定性。



核心网与接入网中的实体面临的安全威胁

- 攻击者可伪造合法用户接入网络服务，诱骗系统资源。
- 在空口拦截过程中，可能追踪、收集用户身份信息并发起进一步攻击。
- 随着无线网络接入点数量和带宽的不断增长，未来这类攻击的成功概率将持续上升。
- 一旦用户无法有效识别服务来源，网络服务方可能被滥用，导致费用损失与资源浪费。



应用安全面临的挑战

- 相比于传统网络架构的安全问题，目前移动通信网络最突出的隐患在于应用安全。
- 应用安全并非指终端操作系统或基站系统漏洞，而是指攻击者利用无线接入路径对应用系统进行入侵。
- 5G网络安全呈现出两个新特征：
 - 空中接口开放性高：如手机与基站之间的通信易被监听或利用。
 - 无线应用复杂多样：易受到木马、病毒、恶意代码的攻击，终端自身成为薄弱点。



4G面向物理与系统的安全加固方案

□物理防护：

- 通过增加温度、电流等参数检测能力，抵抗物理攻击与旁路分析。

□平台加固：

- 引入可信启动机制、完整性检测机制，构建可信执行环境。

□操作系统安全：

- 采用支持隔离控制、远程验证的安全操作系统架构，满足可信计算平台的要求。

- 安全措施需覆盖平台全生命周期，以防止系统被篡改或恶意操作。



5G面向体系结构与服务的综合防护机制

□ 虚拟化环境安全：

- 引入虚拟机隔离、可信执行环境等机制，确保网络功能虚拟化过程中不同服务之间的数据隔离。

□ 网络切片安全控制：

- 对每个网络切片进行独立的认证、访问控制与密钥管理，防止跨切片权限滥用或信息泄露。

□ 服务端到端保护：

- 构建从终端到云平台的统一安全策略，实现多域协同、全生命周期的威胁检测与响应能力。



5G-AKA (Authentication and Key Agreement)

- 5G-AKA是5G系统中的默认认证协议，由核心网与USIM协同完成。
- 延续了3G/4G中的AKA机制，但增强了密钥派生和身份保护能力。
- 特点：
 - 适用于传统SIM卡用户，支持端到端认证与密钥协商。



EAP-AKA (Extensible Authentication Protocol-AKA)

- 是一种基于EAP框架封装的AKA协议，便于在非3GPP接入场景中使用。
- 如Wi-Fi、固定网络、物联网接入时，认证可由第三方认证服务器完成。
- 特点：
 - 跨网络类型兼容性更好，适用于多种异构网络环境。



5G-AKA 与 EAP-AKA 的对比

	5G-AKA	EAP-AKA
协议框架	基于3GPP通信架构	基于EAP通用认证框架
使用场景	5G核心网内部认证，主用于SIM认证	非3GPP接入（如Wi-Fi、固定网）
网络实体	AUSF、UDM、SEAF等	EAP Server、AAA服务器等
协议灵活性	主要面向移动网络	面向异构网络，适用于多接入环境
身份保护机制	支持SUCI/ SUPI隐私保护	身份保护依赖EAP框架机制



关键实体与预共享信息

- 在5G-AKA注册阶段，涉及三个通信实体：
- UE（用户设备）：用户手机等终端设备
- SN（服务网络）：用户当前连接的接入网，例如基站所在网络
- HN（归属网络）：用户所属运营商核心网络



关键实体与预共享信息(2)

- 开始注册前，各实体预存的信息包括：
- UE 已知：本地加密参数 k 、归属网公钥 PK_{HN} 、用户永久标识 $SUPI$ 、序列号 SQN_{UE}
- SN 已知：其自身标识 ID_{SN}
- HN 已知：与UE共享的 k 、归属网私钥 sk_{HN} 、归属标识 ID_{HN} 、本地序列号 SQN_{HN}



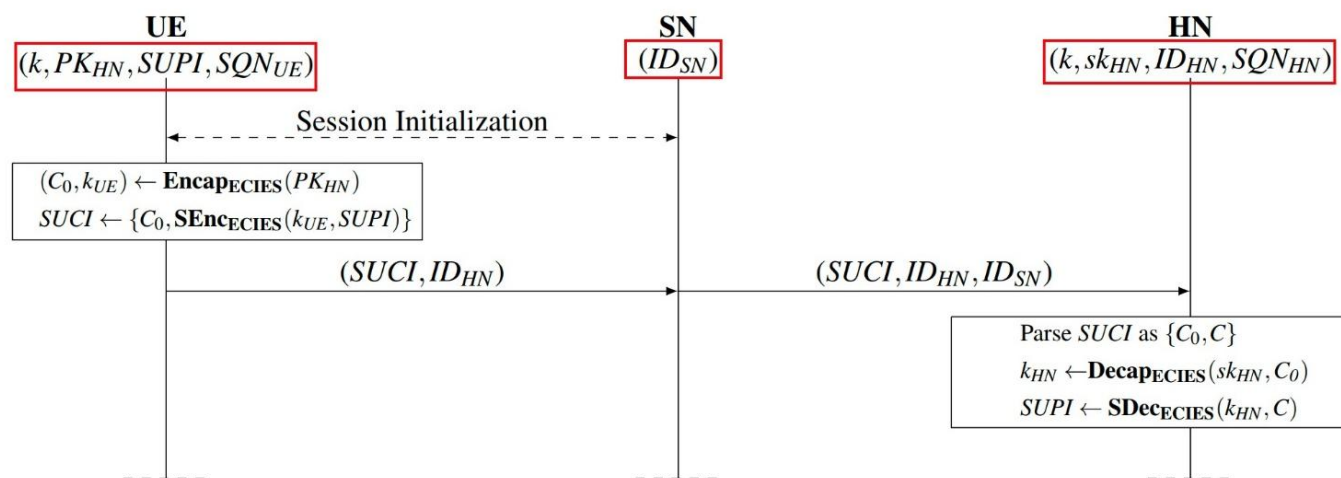
5G中的安全协议

6.3.4 5G-AKA (3)

B U P T

注册过程——加密

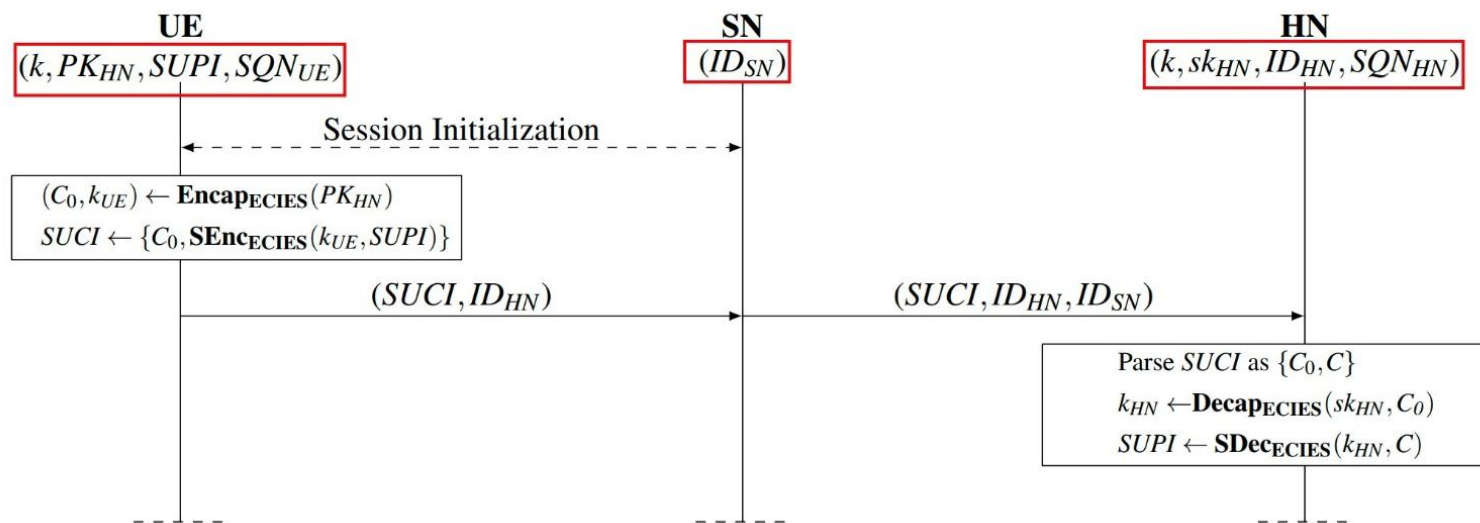
- UE 使用 PK_{HN} 生成一个临时会话密钥 k_{UE} 并对 SUPI 加密
 - 得到 $SUCI = \{C_0, C\}$,
- 其中 C_0 是公钥协商密文, C 是对称加密的内容。





注册过程——加密

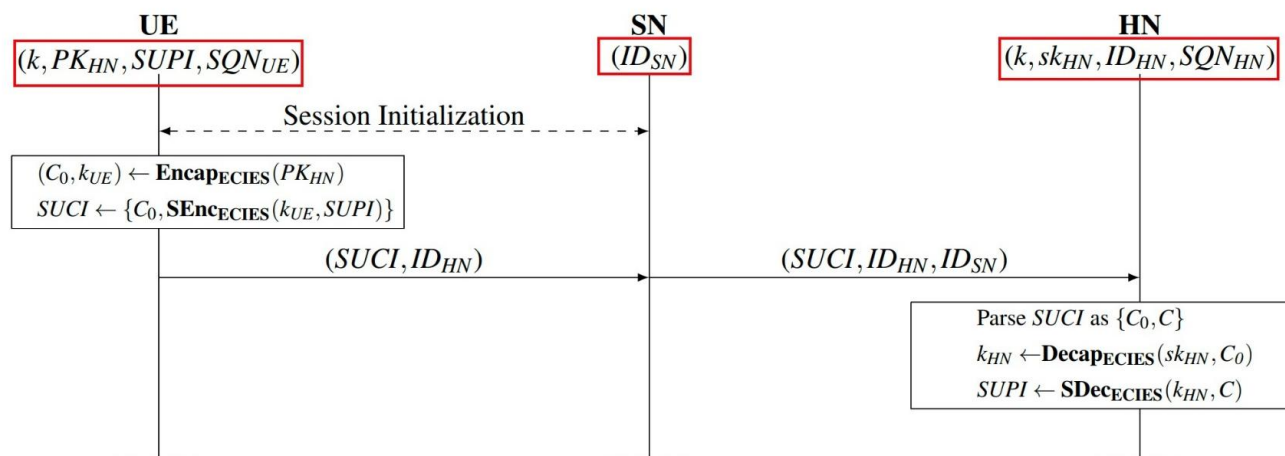
□对 SUPI 进行加密生成临时身份标识 SUCI 的核心目标是解决 4G 及以前的明文传输暴露隐私的问题。





注册过程——信息上送流程

- UE 将 SUCI 和归属网标识 ID_{HN} 发送给服务网络 SN。
- SN 再将自身标识 ID_{HN} 加入其中，一同转发给 HN。





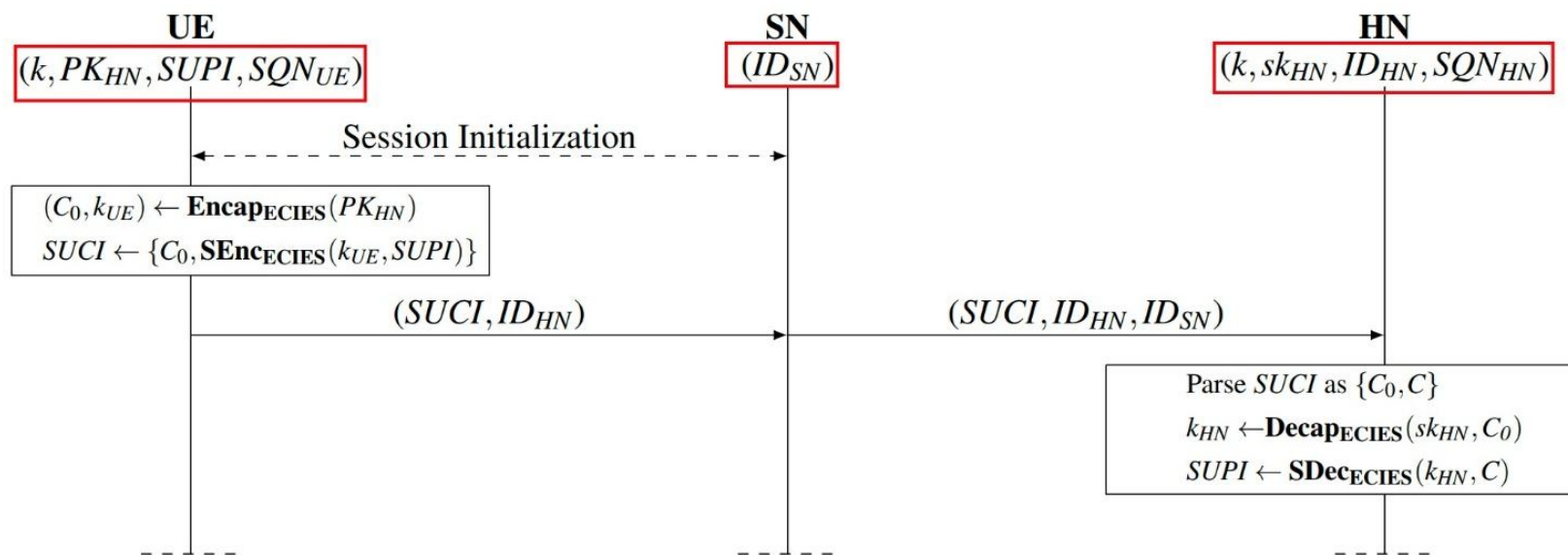
5G中的安全协议

6.3.4 5G-AKA (6)

B U P T

注册过程——HN解析SUCI

□ HN 使用自身私钥 sk_{HN} 解密 SUCI，恢复出 SUPI，从而识别用户身份。





认证过程——前提状态

- 在进入挑战-响应阶段前，各实体已经具备以下共享信息：
 - UE 与 HN 共享主密钥 K
 - SN 已获得 SUCI、并从 HN 获取认证数据
- 此阶段的目标是：
 - 完成双向身份认证，并派生密钥以供后续通信使用



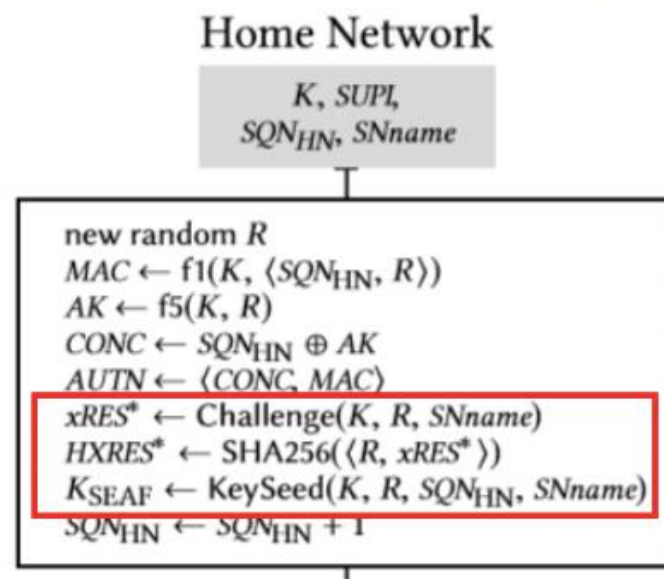
5G中的安全协议

6.3.4 5G-AKA (8)

B U P T

认证过程——HN生成认证四元组

- 生成128位随机数 R
- 构造认证令牌 $AUTN = (CONC, MAC)$, 其中:
 - $CONC = SQN_{HN} \oplus AK$ (隐藏序列号)
 - 计算期望响应 $xRES^*$ 和其哈希 $HxRES^*$
 - 派生锚密钥 K_{SEAF} , 供后续密钥派生使用 (包含服务网标识 $SNname$)





认证过程——SN向UE转发认证数据

- HN将 R 、AUTN、HXRES*、 K_{SEAF} 发给SN
- SN 将 R 和 AUTN 发送给UE



认证过程——UE进行验证与响应生成

- 拆解 AUTN, 还原 SQN_{HN}
- 使用 K 计算本地 MAC 并验证接收到的 MAC 是否一致
 - 若一致, 且 $SQN_{UE} < SQN_{HN}$, 则完成对 HN 的认证
- 计算响应 RES^* 和本地密钥 K_{SEAF} , 发送 RES^* 给 SN

```
 $\langle xCONC, xMAC \rangle \leftarrow AUTN$   
 $AK \leftarrow f5(K, R)$   
 $xSQN_{HN} \leftarrow AK \oplus xCONC$   
 $MAC \leftarrow f1(K, \langle SQN_{HN}, R \rangle)$   
CHECK (i)  $xMAC = MAC$  and  
         (ii)  $SQN_{UE} < xSQN_{HN}$ 
```

```
 $SON_{UE} \leftarrow xSON_{HN}$   
 $RES^* \leftarrow Challenge(K, R, SNname)$   
 $K_{SEAF} \leftarrow KeySeed(K, R, SQN_{HN}, SNname)$ 
```



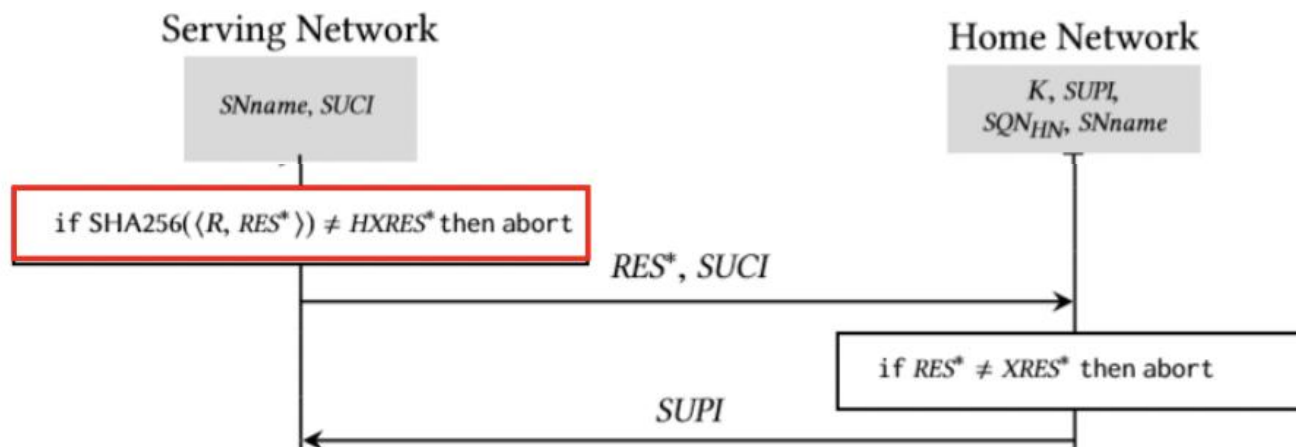
5G中的安全协议

6.3.4 5G-AKA(11)

B U P T

认证过程——SN 与 HN 完成对 UE 的认证

- SN 对 RES^* 进行哈希，验证是否等于 $HXRES^*$
- 若匹配，SN 确认 UE 身份，同时将 RES^* 转发给 HN
- HN 对比收到的 RES^* 与本地 $XRES^*$ ，一致则完成对 UE 的认证





5G-AKA 机制设计特点

- 引入 HXRES*, 加强了对服务网 (SN) 的校验能力, 防止伪造认证。
- 使用服务网标识 SNname 参与密钥派生, 提高密钥绑定性。
- 明确区分认证失败与同步失败, 避免序列号泄露带来的可链接性攻击。



主要参与实体

- UE（用户设备）：发起认证请求并计算响应。
- SEAF（服务网络接入功能）：协调认证流程、转发消息。
- AUSF（认证服务器功能）：执行认证逻辑、校验响应。
- UDM/ARPF（用户数据管理）：存储和提供用户订阅数据、密钥等。

UE

SEAF

AUSF

UDM/ARPF



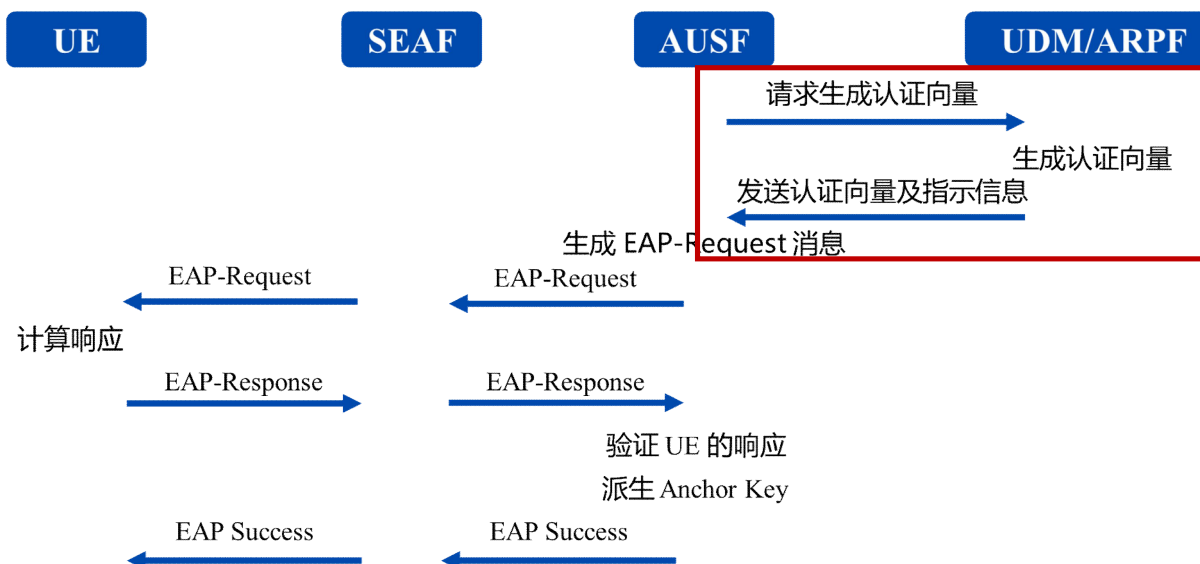
协议设计目标

- 支持异构网络中统一认证
- 提供对 SUPI（用户永久标识）的隐私保护
- 引入 Anchor Key，支持多域密钥衍生与统一管理



认证过程——生成认证向量 (AV)

- AUSF 向 UDM 请求生成认证向量（包含随机数、预期响应等）。
- UDM 向 AUSF 发送认证向量及 SUPI、AKMA 指示信息。





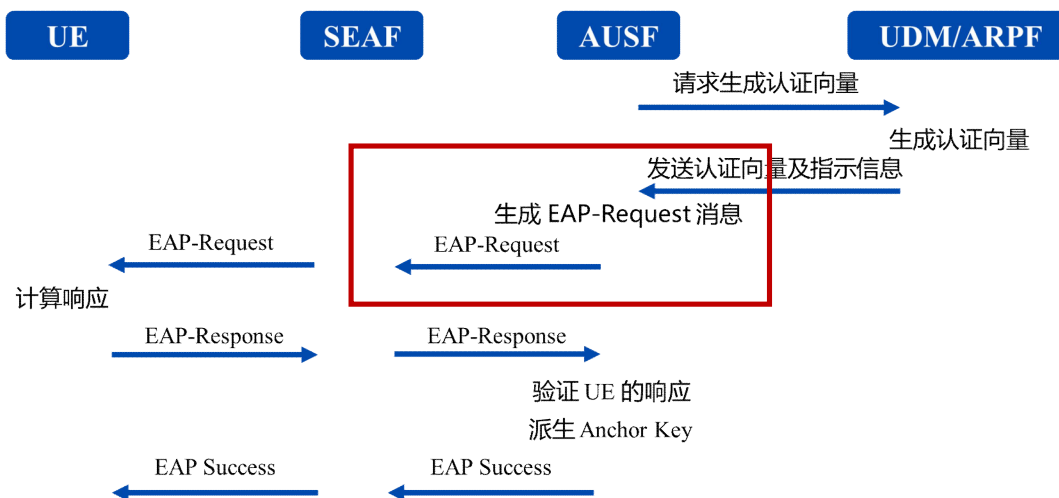
5G中的安全协议

6.3.5 EAP-AKA(4)

B U P T

认证过程——AUSF 向 SEAF 返回挑战信息

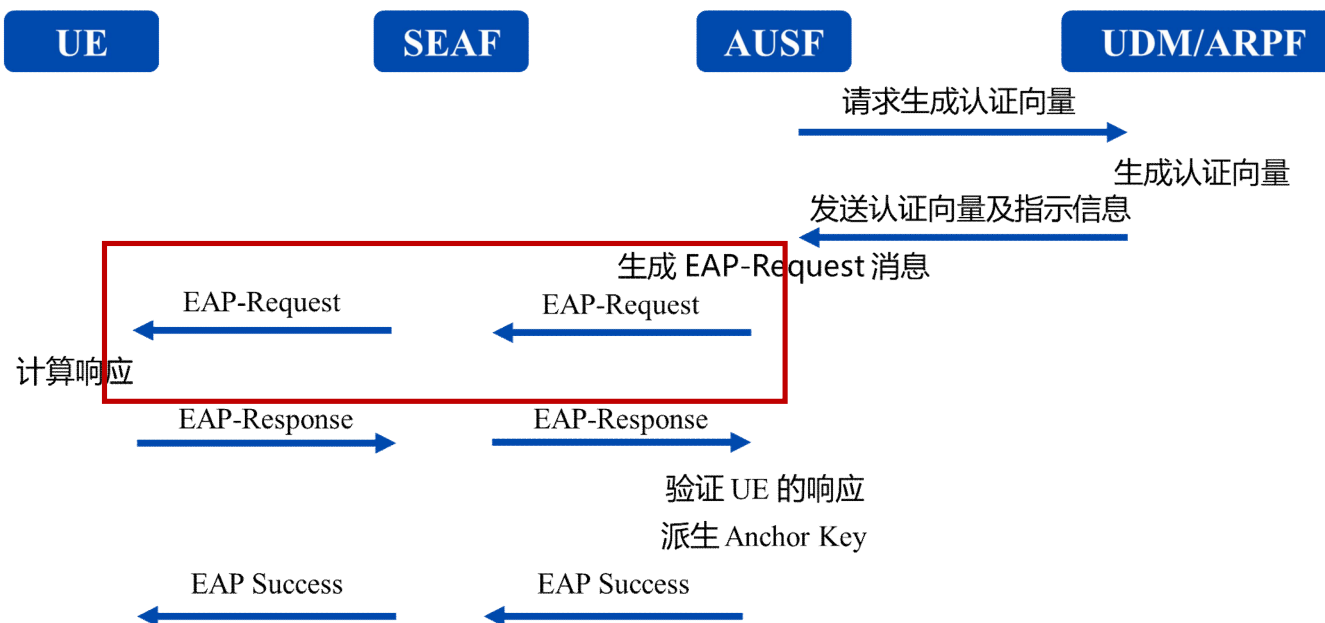
- AUSF 生成 EAP-Request / AKA'-Challenge 消息，包含：
 - 随机数 R、认证令牌 AUTN、密钥选择标识、算法标识参数
- AUSF 将该消息封装并发给 SEAF。





认证过程——SEAF 向 UE 发起认证请求

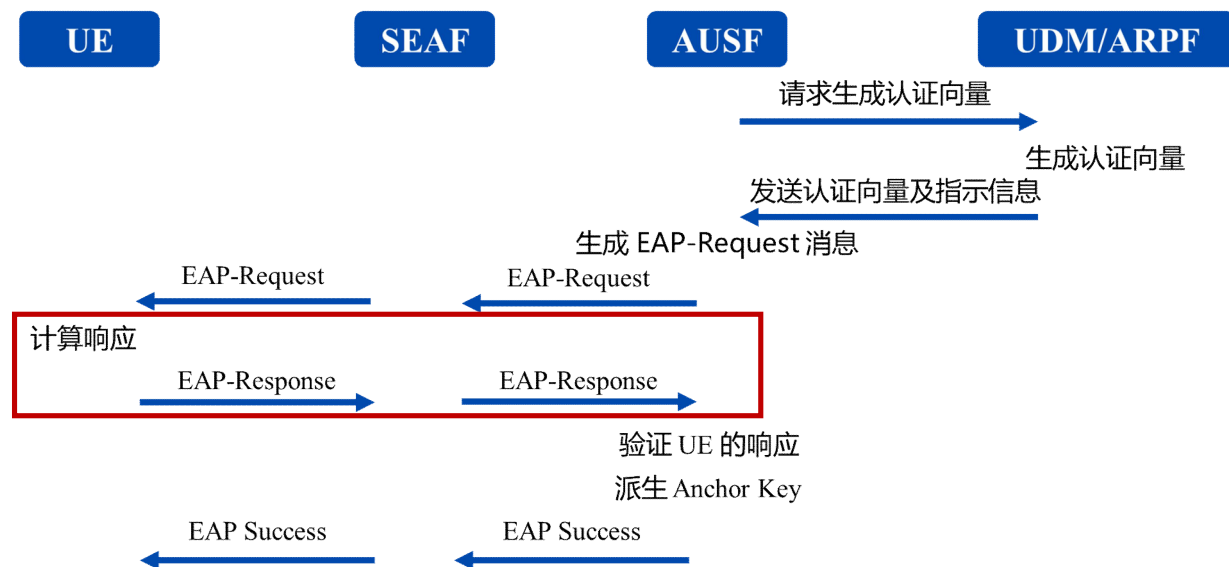
- SEAF 将上述消息转发给 UE。
- UE 接收到挑战后，根据密钥计算响应。





认证过程——UE 生成响应

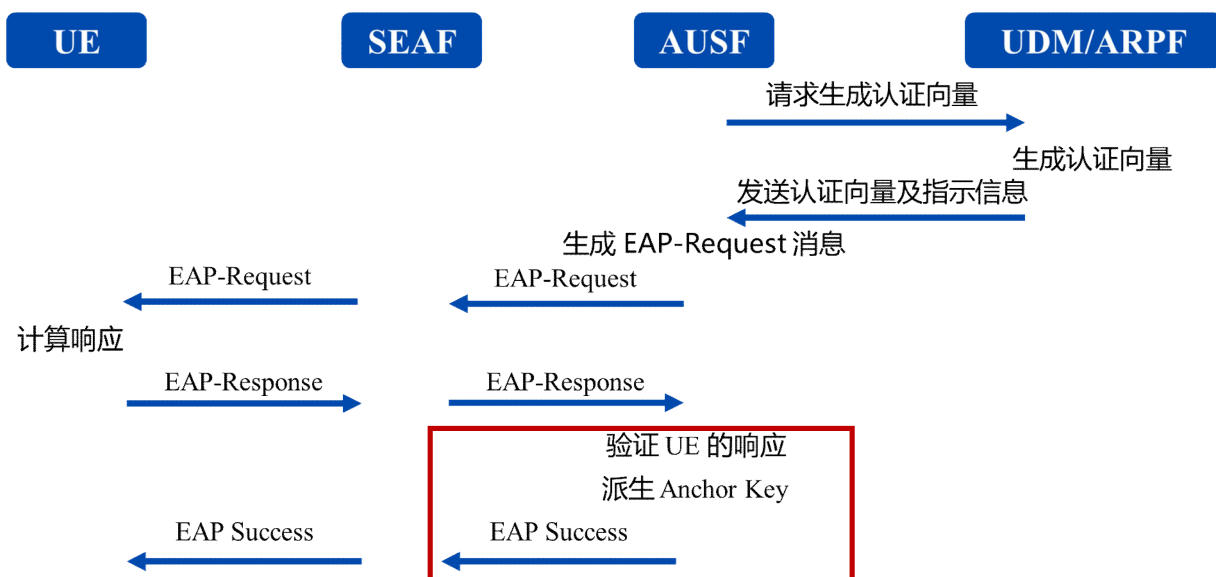
- UE 根据挑战内容与本地 K 值计算 RES（响应），并以 EAP-Response 形式返回给 SEAF。
- SEAF 再将 EAP-Response 转发给 AUSF。





认证过程——校验响应并完成认证

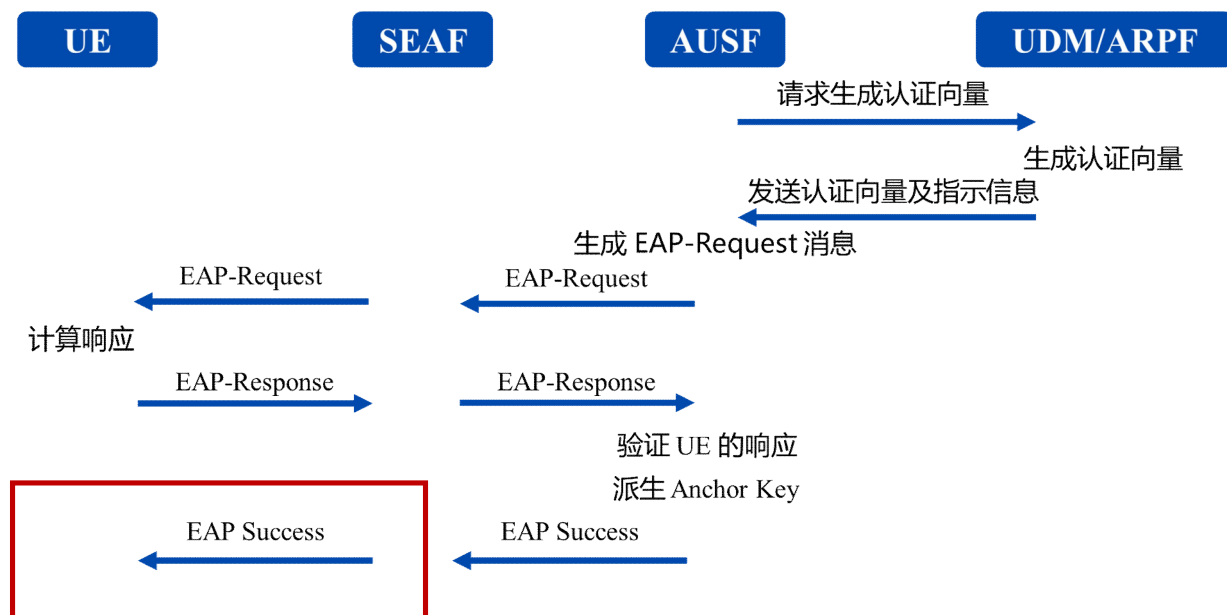
- AUSF 验证 UE 的响应是否匹配预期结果。
- 若成功，返回 EAP-Success，并派生出 Anchor Key K_{AUSF} ；
- 封装消息发送回 SEAF；





认证过程——SEAF向UE发送成功消息

- SEAF 将 EAP Success 消息发送给 UE，并携带一系列参数；
- 此时认证过程结束，双方共享密钥，可用于后续密钥派生与加密通信。





1.在5G系统中，为什么还需要使用两种不同的认证协议（如5G-AKA 与 EAP-AKA）？你觉得它们各自适合怎样的场景？

6.4

区块链

▶ 区块链



✓ 6.4.1 定义

✓ 6.4.2 区块与区块头

✓ 6.4.3 区块链的特征

✓ 6.4.4 工作量证明机制

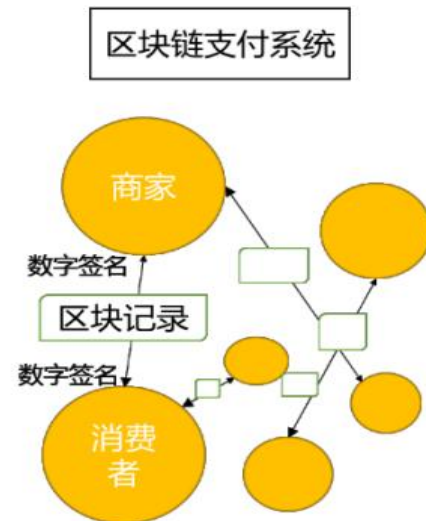
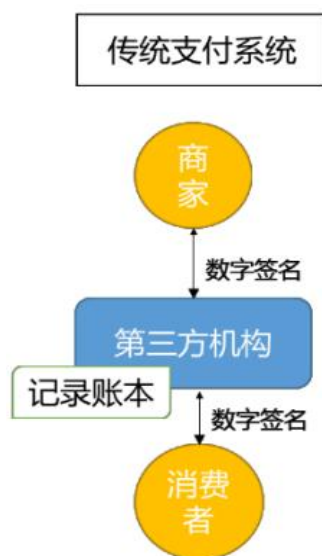
✓ 6.4.5 分叉现象

✓ 6.4.6 双重支付问题



区块链的发展背景

- 在传统互联网支付中，电子交易依赖第三方信用机构（如银行、平台）进行中介与清算。
- 区块链技术通过构建去中心化的分布式系统，实现无需第三方参与的直接支付与记录。





区块链的发展背景

- 区块链是一种分布式账本系统，通过密码学手段保障信息不可篡改与可验证。
- 它以“去信任”为前提，将信任机制从机构转移到技术本身，代表“基于计算的信任”。





从不同角度理解区块链

□从系统结构看：

□区块链是一种去中心化、分布式记账系统，由多个节点共同维护。

□从数据视角看：

□区块链提供分布式存储能力，数据以链式结构组织，不可随意删除或修改。

□所有节点持有同一份数据副本，并共同参与记录与验证，保障数据一致性。



从不同角度理解区块链

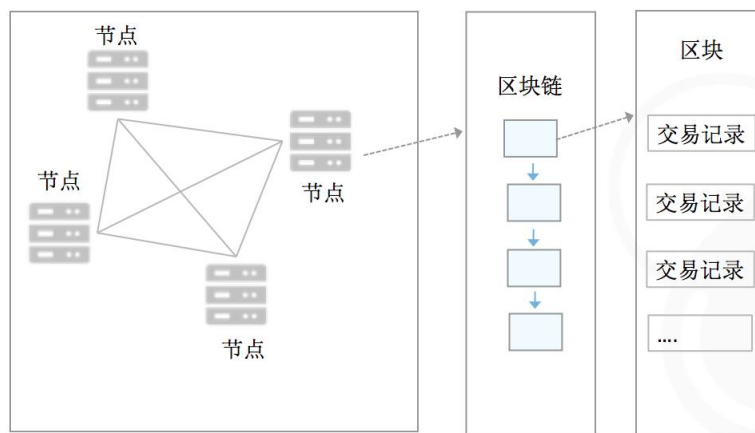
□从技术组合角度看：

- 区块链融合密码学、共识算法、点对点网络、分布式计算等多种技术；
- 它不是单一技术，而是一个多技术集成系统，实现可信记录与价值流通。



什么是“区块”

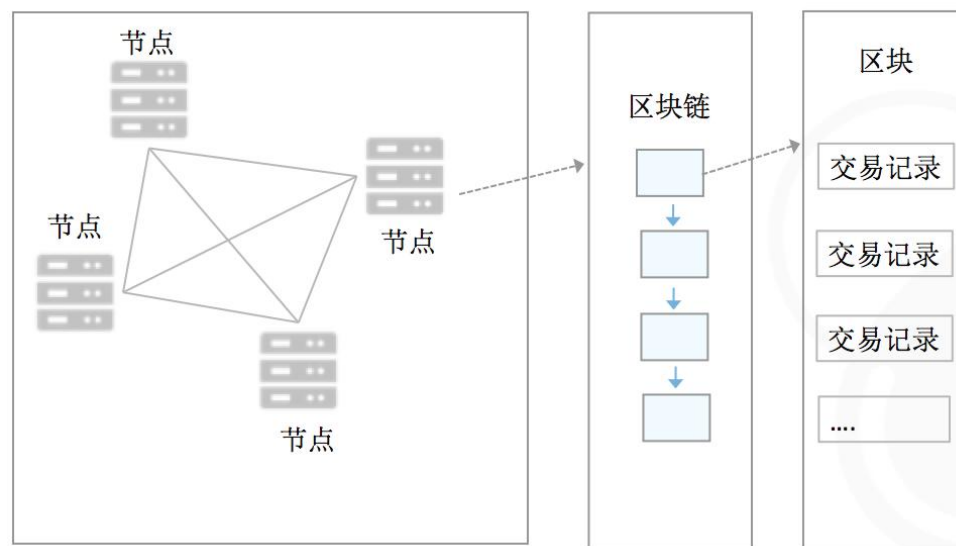
- 区块是区块链中用于记录交易信息的基本单位。
- 每个区块由两部分组成：
 - 区块头：用于链上连接、安全验证等核心功能；
 - 区块主体：用于记录本区块中所有的交易数据。





什么是“区块”

- 每个区块只负责记录一段时间内的交易，多个区块按顺序相连形成“区块链”。
- 区块头的结构设计是保障区块链安全性与可追溯性的关键。





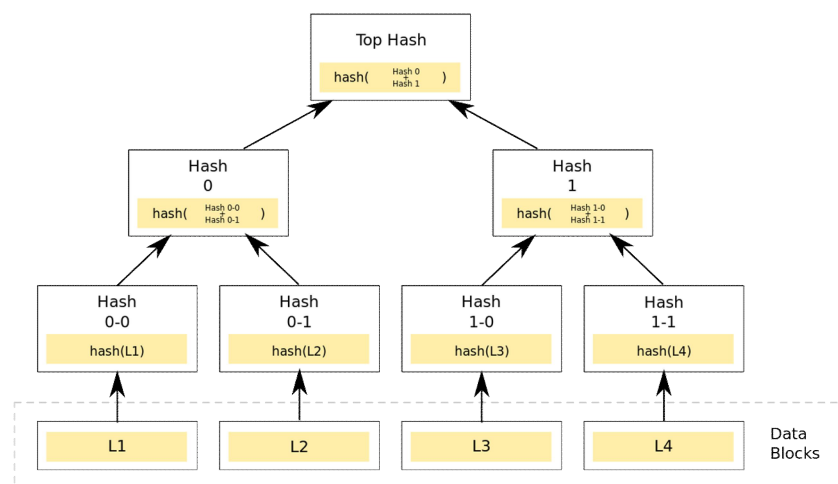
区块头的主要内容

- **版本号**：标明区块使用的软件和协议版本；
- **父区块哈希值**：指向前一个区块头的哈希值，确保区块链结构连续；
- **Merkle根**：由该区块内所有交易的哈希值构成的哈希树根，用于快速验证交易是否存在；
- **时间戳**：记录该区块被创建的具体时间（精确到秒）；
- **难度值**：当前网络设定的数学挑战难度，用于控制出块速度；
- **随机数**：矿工为满足难度要求进行计算得到的解，用于验证计算正确性。



Merkle 树的结构与原理

- Merkle 树是一种用于校验大规模数据完整性的树形数据结构，又称“哈希树”。
- 每一个叶子节点存储的是一笔交易的哈希值；
- 每一个非叶节点是其子节点哈希值的组合再哈希；
- 最上层的根节点称为 Merkle 根（Merkle Root），唯一代表整个数据集。





Merkle 树在区块链中的应用意义

- 区块链中，Merkle 根记录在区块头中，用于快速证明一笔交易是否存在于区块中。
- 优势：
 - 可验证单笔交易而无需下载整个区块；
 - 保证数据完整性，若任一交易被篡改，Merkle 根会随之变化；
 - 支持轻节点（如移动钱包）仅下载区块头和少量路径即可验证交易；



新区块是如何被创建的？

- 在已有区块加入区块链后，节点立即开始创建下一个新区块，过程如下：
- 1、将本节点临时存储中的交易信息写入区块主体；
- 2、以这些交易的哈希值构建一棵 Merkle 树，并将 Merkle 根写入区块头；
- 3、提取上一块区块的哈希值，作为新区块的“父区块哈希”，写入区块头。



新区块是如何被创建的？

- 4、获取当前时间，并作为时间戳记录在区块头中；
- 5、网络通过调整“难度值”来控制出块速度：
 - 如果最近区块生成速度过快，将提高难度；
 - 如果速度变慢，则降低难度；
- 6、节点不断尝试不同的随机数解密该难题，直到找到满足难度条件的解，完成区块生成。



关键特征总结

□ 开放共识：

□ 任何节点都可加入网络，每个节点维护完整账本，共识机制确保一致性。

□ 去中心、去信任：

□ 数据交换不依赖中心机构，节点间通过算法规则进行验证。



关键特征总结

□交易透明，用户匿名：

- 交易内容公开可查，任何节点都可查看；
- 用户身份无需公开，节点之间可匿名交互。

□不可篡改，可追溯：

- 一旦写入区块的数据几乎无法更改；
- 所有数据均通过密码学签名连接，可完整追踪数据来源与交易历史。



工作量证明的核心原理

- 区块头包含一个随机数字段，系统要求通过不断尝试不同随机数，使得区块的哈希值满足某种条件（如前 n 位为0）。
- 找到满足条件的随机数需要大量计算，因此被视为“做出了工作”。
- 该机制被称为工作量证明（PoW），是一种基于计算能力进行竞争的共识方式。



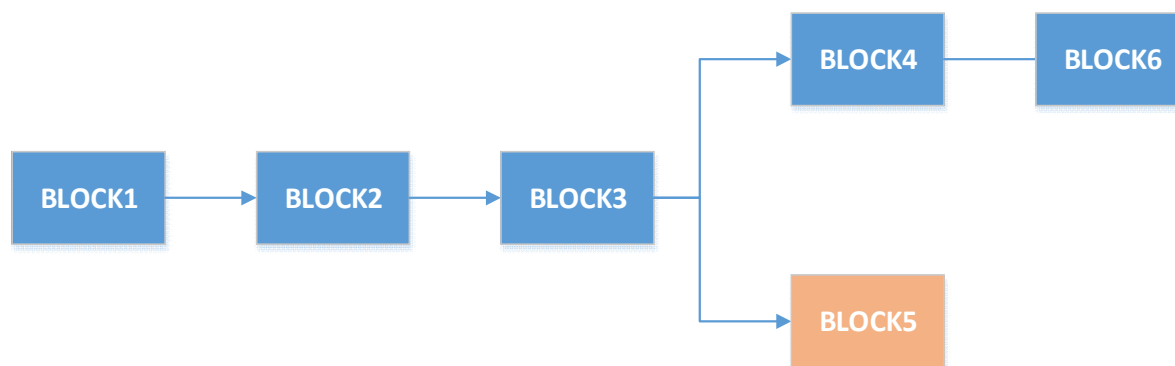
工作量证明的安全含义

- 网络中最长的链被认为是“最有效的链”，因为其包含了最多的计算工作；
- 攻击者若试图篡改某区块，必须重新计算该区块及其之后所有区块的工作量，并追上主链，这在算力受限条件下几乎不可能。



区块链中的分叉现象

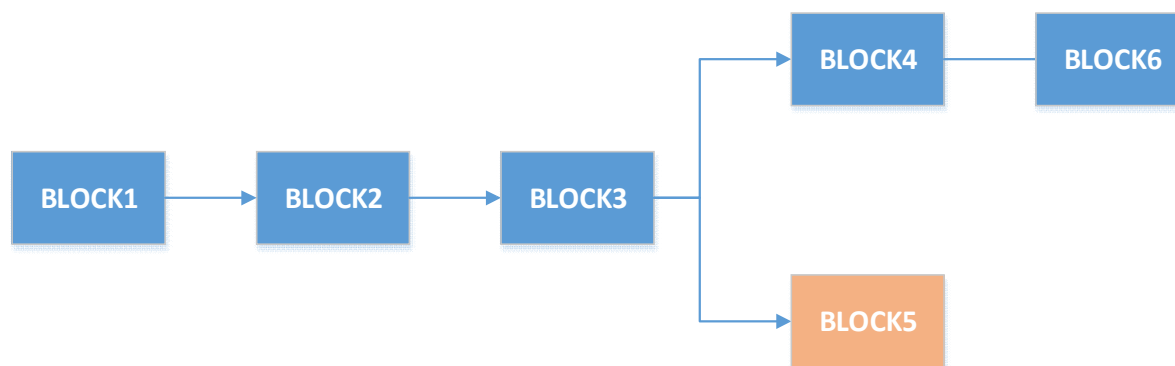
- 在相同时间内，可能多个节点各自计算出合法新区块，并将其广播至全网。
- 某节点若接收到多个基于同一前一区块的后续新区块，将在本地区块链中形成多个“分叉”。
- 此时所有分支均为临时有效，系统会等待下一次出块。





分叉处理机制：

- 当后续新区块陆续产生时，链条最长的那一支会被大多数节点认定为主链；
- 其他较短的分支将被抛弃，其包含的交易将回到待确认池中，等待重新打包。





什么是双重支付

- 双重支付是指：攻击者试图将同一笔加密货币用于两次不同交易；
- 例如向商家 A 支付后，又试图向商家 B 使用相同资金再次支付。
- 区块链的防护机制：
 - 每个节点在打包交易前，会回溯并验证交易中资金的来源是否合法；
 - 每笔交易可以被追溯到初始产生该货币的区块；
 - 系统采用统一规则选定哪些交易进入最终区块，并以时间先后作为排序标准。



双重支付为何难以实现？

- 虽然攻击者可将重复交易广播至网络，但只有其中一条交易最终被写入区块链；
- 所有节点在记录前会验证这笔钱是否“已被花过”；
- 一旦某笔交易被加入某一区块并被确认，系统中其他副本将永久记住该资金已使用；
- 因此任何试图篡改交易来源的行为都会被链上记录追溯并识别，难以成功。



2.区块链去掉了“第三方信用机构”，但你觉得真的“完全不需要信任”了吗？如果没有政府或平台来兜底，风险会更大吗？

谢谢大家
